Addis Ababa Science and Technology University

Department of Software Engineering

Computer System Security

Project Two

Project features

- **Access Control and Authentication:**

1. Mandatory Access Control (MAC):

   a. Enforce strict access policies where access to information is determined by the system, not user discretion.
   b. Classify the data into sensitivity levels such as *Confidential, Internal, and Public*.
   c. Assign security labels to users and data (e.g., managers can view "Confidential" salary data, regular employees cannot).
   d. Restrict access changes to only system administrators to maintain data integrity and confidentiality.

2. Discretionary Access Control (DAC):

   a. Allow resource owners (e.g., staff or department heads) to grant or revoke permissions for specific files or records they own.
   b. Enable file-level and record-level permission controls for shared documents like performance reports and employee forms.
   c. Maintain permission logs showing who granted, modified, or accessed shared resources.

3. Role-Based Access Control (RBAC):

   a) Define roles within the project system based on job responsibilities and hierarchy.
   b) Assign specific access permissions to each role based on the tasks.
   c) Develop a mechanism for assigning and modifying roles
   d) Allow for dynamic changes to roles for role change requests and approvals.
   e) Maintain an audit trail for role assignments and changes.

4. Rule-Based Access Control (RuBAC):

   a. Define rules that restrict access based on conditions such as time, location, or device.
   b. Example: Deny system access outside working hours unless preapproved.
   c. Implement conditional rules like "only HR Managers can approve leave requests exceeding 10 days."

5. Attribute-Based Access Control (ABAC):

   a. Implement fine-grained control using attributes such as user role, department, location, and employment status.
   b. Example: "Employees in the Payroll Department" can access salary data, but "Employees in IT" cannot.
   c. Combine multiple attributes to decide access dynamically — e.g., role + department + time of access (a "Manager" in the "Finance Department" can approve reports only during working hours).
   d. Integrate ABAC with policy decision points for real-time enforcement.

- **Audit Trails and Logging:**

   a. User Activity Logging:
   b. Log all user activities within your project titles, include details such as the username, timestamp, IP address, and the specific action performed.
   c. System Events Logging:
   d. Log critical system events such as system startup, shutdown, and configuration changes.
   e. Log Encryption:
   f. Implement encryption for stored logs to protect sensitive information
   g. Centralized Logging:
   h. Aggregate logs in a centralized location for easier monitoring and analysis.
   i. Alerting Mechanisms:
   j. Implement alerting mechanisms for critical events or anomalies identified in the logs.

- **Data Backups:**

   a. Regular Backups: Implement routine data backups to ensure data availability.

- **Identification and Authentication:**

   a. User Registration
      - Design a secure registration collects information.
      - Implement email verification or mobile phone verification

b. Preventing Fake Accounts: bot prevention
    - Implement Captcha to prevent from creating fake accounts.
    - Choose user-friendly Captcha that don't create difficulty for genuine users
c. User Profiles
    - Implement features for users to update and manage their profiles securely.
d. Biometric Authentication: if applicable

- **Implement Password Authentication**
    a. Password Policies:
        - Enforce password policies with minimum length, complexity requirements
        - Provide guidance to users on creating secure passwords.
    b. Password Hashing:
        - Implement best hashing algorithms to securely store passwords.
        - Implement a mechanism to protect attacks like rainbow table attacks.
    c. Account Lockout Policy:
        - Implement an account lockout policy to prevent brute-force attacks.
        - Specify thresholds for unsuccessful login attempts before an account is temporarily or permanently locked.
    d. Secure Password Transmission:
        - Implement a mechanism to transmit passwords securely over channels
    e. Password Change:
        - Implement a mechanism to change passwords

- **Token-Based Authentication:**
    a. Implementing token-based authentication
    b. Session Management:

- **Multi-Factor Authentication (MFA):**
    a) Implement username password authentication
    b) Implement at least one MFA methods such as one-time passwords (OTP), or biometrics or tokens